Защита лабораторной Week 9

Threat hunting с Atomic Red Team и Elasticsearch

Гайд для устной защиты и воспроизводимой демонстрации. Главный результат: три исходных детектора проверены на 78 868 записанных Windows-событиях; выбранные сценарии сопоставлены с конкретными тестами официального Atomic Red Team. Запуск этих Atomic-тестов на Windows в данной работе не подтверждён.

Речь на одну или две минуты

«В этой работе я проверяю гипотезы обнаружения двух видов активности: создания запланированной задачи с подозрительным действием и установки Windows-службы с командным интерпретатором в пути запуска.

Стенд работает на Fedora. В rootless-контейнере Podman запущен Elasticsearch 9.5.5, доступный только через localhost. В индекс winlogs загружены девять официальных наборов OTRF, всего 78 868 событий. Это записанная телеметрия Windows, а не события атак, выполненных на моём ноутбуке.

Я использую три исходных ES|QL-запроса и проверяю происхождение данных и запросов по закреплённым версиям и хешам. Для связи с Atomic Red Team добавлена проверка метаданных официального репозитория: конкретных GUID, названий тестов и платформ. Затем тесты сопоставляются с детекторами и аналогичной записанной телеметрией.

Результат исходных запросов: одно событие создания задачи, два события одного процесса schtasks.exe из разных журналов и одно событие установки службы. На семи фоновых наборах совпадений нет. Это результат на выбранной выборке, а не доказательство нулевого числа ложных срабатываний в реальной сети.

Основное ограничение: я проверил выполнение запросов в Elasticsearch и сопоставление с Atomic, но не выдаю записанные OTRF-события за результат живого запуска Atomic. Для такого доказательства нужна отдельная разрешённая Windows-лаборатория и цепочка свидетельств от запуска конкретного теста до события и срабатывания детектора».

Четыре числа для защиты

- 9 наборов данных; 78 868 документов в winlogs.
- 3 исходных ES|QL-детектора.
- 1 / 2 / 1 строки результатов в порядке task creation / process / service.
- 0 совпадений на 7 фоновых наборах, только в рамках этой проверки.

Две ошибки которые нельзя повторять

Две строки process-запроса не означают два разных процесса. Это Sysmon Event ID 1 и Security Event ID 4688, описывающие один schtasks.exe. Родительский PowerShell виден в поле ParentImage одной записи, но не является отдельной строкой этого результата.

Event ID 7045 относится к System. Провайдер Service Control Manager фиксирует установку службы. Указание Security в комментарии исходного service-запроса неточно; запрос оставлен неизменённым ради воспроизводимости.

1 Что именно исследуется

Роли трёх компонентов

MITRE ATT&CK описывает тактики, техники и подтехники поведения противника. T1053.005 обозначает Scheduled Task, T1543.003 обозначает Windows Service, T1569.002 обозначает Service Execution. Код техники помогает сформулировать гипотезу, но сам по себе не задаёт детектор.

Atomic Red Team содержит небольшие тесты, привязанные к ATT&CK. У каждого теста есть GUID, имя, поддерживаемые платформы, исполнитель, входные параметры и другие метаданные. Совпадение номера техники ещё не означает, что любой её тест удовлетворяет условиям конкретного запроса.

Elasticsearch и ES|QL здесь используются для хранения событий и проверки гипотез. Это аналитический стенд для части SIEM-процесса. В работе не заявлены полноценные оповещения, инцидент-менеджмент или развёрнутый SOC.

Логика проверки

Гипотеза поведения → ожидаемые поля журналов → условия ES|QL → совпадения в записанных данных → проверка контекста и ограничений.

Отдельная ветка проверки: официальный Atomic YAML → закреплённый commit → GUID и параметры теста → обоснованное соответствие условиям детектора. Параметр --atomic-root позволяет проверять локальный checkout официального репозитория с закреплёнными метаданными; код из него не исполняется. Эта ветка описывает ожидаемую связь, но не создаёт доказательство фактического исполнения теста.

Выбранные тесты официального Atomic Red Team

Scheduled Task Executing Base64 Encoded Commands From Registry

- Техника: T1053.005; платформа: Windows; исполнитель: command_prompt.
- GUID: e895677d-4f06-49ab-91b6-ae3742d0a2ba.
- YAML: atomics/T1053.005/T1053.005.yaml.
- Связь: действие задачи содержит PowerShell и декодирование Base64; создание через schtasks соответствует двум task-детекторам при наличии нужного аудита и полей.
- Записанный аналог: empire_schtasks_creation_execution_elevated_user. Его MordorElevated не следует переименовывать в Atomic-задачу: источник остаётся OTRF.

Execute a Command as a Service

- Техника: T1569.002; платформа: Windows; исполнитель: command_prompt.
- GUID: 2382dee2-a75f-49aa-9378-f52df6ed3fb1.
- YAML: atomics/T1569.002/T1569.002.yaml.
- Связь: стандартный путь запуска службы содержит %COMSPEC% и PowerShell, что соответствует service-детектору при наличии события 7045.
- Записанный аналог: empire_psexec_dcerpc_tcp_svcctl. Событие Updater подтверждает установку службы, но само по себе не доказывает запуск или удалённое перемещение.

В каталоге выбранных YAML проверено 28 официальных тестов; для связи с тремя запросами выбраны два GUID. Закреплённая версия Atomic: a0e3f9bc69fed2fd711bd1f1aa87a40c33482fe6. Нельзя подменять выбранные тесты любым тестом той же техники. Например, обычная задача с cmd.exe или служба с AtomicService.exe может не пройти узкие исходные фильтры.

2 План демонстрации

До защиты

Откройте каталог лаборатории и проверьте, что есть данные, source/week9/queries и output. В Git-версии проекта лаборатория находится в week9/local_lab. Команды ниже выполняются из каталога, содержащего start-lab.sh и run_week9.py. Первый запуск с загрузкой данных требует сети; уже подготовленную проверку лучше выполнить заранее.

```
cd /home/lapis/threat-hunting-project-week9-atomic/week9/local_lab
bash start-lab.sh
python3 atomic_week9.py verify
python3 atomic_week9.py run
```

Эти команды запускают локальный контейнер, проверяют закреплённые Atomic YAML, импортируют записанные события и выполняют запросы. Режим run остаётся recorded-equivalent, а atomic_execution_verified остаётся false. Команда python3 atomic_week9.py catalog показывает компактный список выбранных тестов. Базовый запуск без Atomic-отчёта доступен через python3 run_week9.py. Командные строки внутри журналов обрабатываются как данные, их нельзя копировать в терминал для исполнения.

Что показать на экране

1. README локальной лаборатории: назначение, режим recorded data и ограничения.
2. Метаданные Atomic и выбранные GUID: версия репозитория, Windows, два теста, связь с тремя детекторами.
3. Запуск проверки и итоговую строку PASS с 78 868 событиями и счётчиками 1 / 2 / 1.
4. output/results.json: версию Elasticsearch, количество событий, dataset_counts и результаты запросов.
5. Исходные queries и по одному примеру результата. Длинные CommandLine и ImagePath обсуждайте как поля журналов, а не как инструкции запуска.
6. Манифесты происхождения и ограничение: Atomic-тесты не исполнялись в этом стенде.

Безопасная проверка API

```
curl -s http://127.0.0.1:9201/_cluster/health
curl -s http://127.0.0.1:9201/winlogs/_count
```

Ожидается green и count 78868. Green говорит о состоянии шардов кластера, а не о качестве детектирования. Отсутствие Kibana не мешает показать ES|QL через скрипт и API.

Файлы доказательств

- output/atomic-plan.json и output/atomic-catalog.json: проверенные метаданные и выбранные Atomic-тесты.
- output/atomic-coverage.json и output/atomic-coverage.txt: связь тестов с наблюдаемой записанной телеметрией и явные ограничения покрытия.
- output/results.json и output/results.txt: результаты выполнения исходных запросов.
- output/data-manifest.json: источники данных, хеши и число записей.
- output/source-manifest.json: происхождение исходных файлов задания.
- output/verification.json: зафиксированная проверка контейнера и стенда; смотрите время проверки, не выдавайте старый файл за свежий запуск.
- source/week9/queries/: неизменённые ES|QL-запросы задания.

Если что-то пошло не так

Connection refused: сначала запустите start-lab.sh и дождитесь готовности API. **Неверное число документов или совпадений:** проверьте манифесты, ошибки импорта и текущую версию файлов; не меняйте ожидаемые числа ради PASS. **Ошибка хеша:** выясните, какой источник изменился, вместо отключения проверки. **Нет сети:** показывайте сохранённые результаты с их датой и отдельно говорите, что свежий запуск не выполнен.

Остановка без удаления данных: podman stop threat-hunting-week9-es. Не удаляйте том и не меняйте системные настройки ради демонстрации.

3 Как объяснить детекторы задач

Создание задачи с подозрительным действием

Файл det-schtasks-persistence.esql проверяет Security 4698. Содержимое TaskContent должно включать PowerShell, -enc, IEX или FromBase64String. Это эвристика подозрительного действия задачи, а не поиск любой задачи планировщика.

```
FROM winlogs
| WHERE EventID == 4698
  AND (TO_LOWER(TaskContent) LIKE "*powershell*"
    OR TO_LOWER(TaskContent) LIKE "*-enc*"
    OR TO_LOWER(TaskContent) LIKE "*iex*"
    OR TO_LOWER(TaskContent) LIKE "*frombase64string*")
| KEEP @timestamp, dataset, Hostname, SubjectUserName, TaskName
| SORT @timestamp
```

Результат: одна запись, WORKSTATION5.theshire.local, пользователь pgustavo, задача \MordorElevated, 2020-09-21 21:58:19.640 UTC. Дата события относится к исходному набору, а не к дате импорта в стенд.

Почему это подозрительно: задачи дают возможность повторного запуска, а скриптовый интерпретатор и кодированные команды требуют контекстной проверки. Администраторы тоже могут создавать такие задачи. Нужны автор, назначение, время, содержимое действия и связь с другими событиями.

Создание задачи со стороны процесса

Файл det-schtasks-process.esql использует Sysmon 1 или Security 4688. COALESCE выбирает имеющееся поле Image или NewProcessName; приведение к нижнему регистру уменьшает зависимость от регистра пути и аргументов.

```
FROM winlogs
| WHERE EventID IN (1, 4688)
  AND ENDS_WITH(TO_LOWER(COALESCE(Image, NewProcessName)), "\\schtasks.exe")
  AND TO_LOWER(CommandLine) LIKE "*/create*"
  AND (TO_LOWER(CommandLine) LIKE "*powershell*" OR TO_LOWER(CommandLine) LIKE "*-enc*" OR
TO_LOWER(CommandLine) LIKE "*iex*")
| KEEP @timestamp, dataset, Hostname, User, ParentImage, CommandLine
| SORT @timestamp
```

Результат: две записи на WORKSTATION5 в 21:58:18.599 и 21:58:18.653 UTC. Это два источника телеметрии одного schtasks.exe. Пустые User и ParentImage во второй строке означают различие схем журналов, а не отсутствие пользователя или родителя в реальности.

Почему нужны два детектора: аудит создания задачи и аудит запуска процесса дают разные точки наблюдения. Process-детектор может помочь при отсутствии 4698, но требует сбора командной строки. Он не обнаружит создание через другой API без schtasks.exe.

Дополнительные проверки адаптации

Пройдены 20 тестов: 11 unit-проверок метаданных, GUID, платформ, отсутствия исполнения и сохранения происхождения данных; ещё 9 read-only проверок выражений ES|QL на строках стандартных действий и негативных примерах. Проверены также null, COALESCE и регистр. Синтетические события в индекс не добавлялись. Эти тесты проверяют предикаты, но не заменяют живую телеметрию Atomic.

```
WEEK9_TEST_ES=1 python3 -m unittest discover -s tests -v
```

Контейнер ограничен 3 GiB RAM и 2 CPU. Аутентификация отключена только для согласованной локальной лаборатории; порт привязан к 127.0.0.1:9201. Не меняйте привязку на 0.0.0.0 и не загружайте сюда личные данные.

4 Служба и границы результатов

Установка службы с командным интерпретатором

Файл det-service-lateral.esql выбирает Event ID 7045, если ImagePath содержит PowerShell, cmd, -enc или %COMSPEC%. Это узкое правило для подозрительного пути запуска службы.

```
FROM winlogs
| WHERE EventID == 7045
  AND (TO_LOWER(ImagePath) LIKE "*powershell*"
    OR TO_LOWER(ImagePath) LIKE "*cmd*"
    OR TO_LOWER(ImagePath) LIKE "*-enc*"
    OR TO_LOWER(ImagePath) LIKE "*%comspec%*")
| KEEP @timestamp, dataset, Hostname, ServiceName, ImagePath
| SORT @timestamp
```

Результат: одна запись System / Service Control Manager, служба Updater на WORKSTATION6.theshire.local, 2020-09-20 16:16:58.233 UTC. В ImagePath присутствуют командный интерпретатор и PowerShell.

Что можно сказать: установлена служба с подозрительным путём запуска. Это связано с поведением T1543.003 и сценарием T1569.002. **Чего недостаточно:** одно 7045 не доказывает запуск службы, успешное выполнение команды, компрометацию или lateral movement. Для таких выводов нужны дополнительные события процесса, службы, аутентификации и сетевого взаимодействия.

Как читать ES|QL

- FROM выбирает индекс; WHERE задаёт условия отбора.
- AND требует одновременного выполнения условий; OR допускает альтернативные признаки.
- LIKE с * ищет подстроку. Это не полноценный разбор PowerShell, XML задачи или командной строки.
- KEEP ограничивает видимые столбцы, но не меняет смысл отбора.
- SORT упорядочивает строки по времени события. Он не выполняет корреляцию между событиями.

Ограничения которые важно назвать

Нет доказательства живого Atomic-запуска. Проверенные YAML и сопоставление поведения дают ожидаемое покрытие. Фактический результат конкретного теста должен иметь собственные свежие журналы и идентификатор запуска.

Нет оценки общего false positive rate. Семь фоновых учебных наборов не равны репрезентативной выборке нормальной сети. Ноль совпадений не позволяет заявлять точность 100 процентов.

Нет полного покрытия техник. Правила зависят от конкретных строк, полей и включённого аудита. Другие способы создания задач, пути бинарников, обфускация и отсутствующие поля могут дать пропуски.

Нет автоматической классификации события как атаки. Легитимный администратор может использовать PowerShell и службы. Нужны контекст, baseline и проверяемые исключения. Исключения следует добавлять по обоснованным условиям, а не отключать правило целиком.

Схема учебная. Используются исходные Windows-поля, а не универсальная нормализованная ECS-схема. В рабочей системе надо проверить соответствие полей, провайдер, канал журнала и временные зоны.

5 Ответы на вопросы преподавателя

Где здесь Atomic если события взяты из OTRF

Atomic задаёт конкретные проверяемые сценарии и их метаданные; OTRF предоставляет записанную телеметрию аналогичного поведения. В этой версии интеграция с Atomic означает закреплённый источник, проверку выбранных тестов и mapping к детекторам. Это не отчёт о выполнении Invoke-AtomicTest.

Почему не достаточно номера техники

Внутри одной техники много реализаций. Исходное правило ищет конкретные строки, например PowerShell в действии задачи. Тест с другим стандартным действием может относиться к T1053.005 и всё равно не совпасть с запросом.

Что доказывает PASS

Успешное выполнение предусмотренных скриптом проверок: целостность выбранных входов, импорт и ожидаемые результаты запросов. Надо различать PASS локального воспроизведения и факт успешного запуска атакующего сценария. Второй здесь не заявлен.

Зачем фиксировать commit и хеши

Commit определяет версию репозитория, а хеш проверяет конкретные полученные байты. Это помогает воспроизвести исследование и обнаружить изменение входных файлов. Сам хеш не доказывает безопасность содержимого или полноту метода.

Почему 78 868 событий а совпадений всего четыре строки

Запросы узкие и ищут определённое поведение. Сумма строк не равна числу инцидентов: две строки process-запроса описывают один процесс, а task-событие связано с тем же эпизодом. Между тремя запросами нет автоматической дедупликации инцидентов.

Почему служба относится к двум техникам

Создание или изменение Windows-службы и выполнение через службу являются связанными, но различными действиями. 7045 подтверждает установку; для утверждения о выполнении нужны дополнительные свидетельства. Название файла lateral не меняет эту границу доказательства.

Почему не запустить Windows Atomic на Fedora

Поддерживаемая платформа выбранных тестов Windows. Fedora здесь выполняет роль хоста SIEM-лаборатории и обработки данных. Наличие PowerShell на Linux само по себе не создаёт Windows Event Log, Task Scheduler и Service Control Manager.

Можно ли получить false positive

Да. Например, администрирование может создавать задачу с PowerShell. Проверка начинается с автора, назначения, контекста процесса и других событий. Нулевое число совпадений на небольшой фоновой выборке не отменяет этот риск.

Как улучшить работу дальше

Добавить отдельную Windows-VM, корректно настроить сбор журналов и сохранить результаты конкретных тестов. Затем расширить фоновые данные, добавить корреляцию и дедупликацию, тесты негативных случаев и проверку нормализации полей. Эти шаги являются планом, а не уже выполненной частью работы.

Что сделано самостоятельно в адаптации

Воспроизводимый локальный стенд, безопасная обработка записанных данных, проверка происхождения, импорт и проверка результатов, привязка к конкретным официальным Atomic-тестам и явное разделение ожидаемого и наблюдаемого покрытия. Исходные запросы имеют указанное авторство и сохранены для сравнения.

6 Как подтвердить настоящий запуск Atomic

Требования к отдельному эксперименту

Для живого доказательства нужен отдельный согласованный эксперимент в изолированной Windows-VM. До него следует определить разрешённый тест и пределы воздействия, создать snapshot, убрать реальные учётные данные и личные файлы, ограничить сеть и подготовить восстановление. В этом гайде намеренно нет команд выполнения атакующих сценариев.

1. Зафиксировать точный commit Atomic, GUID, параметры теста, версию Windows, имя VM, временную зону и интервал эксперимента.
2. Проверить аудит и сбор нужных источников: Security 4698, Security 4688 с командной строкой, Sysmon 1 и System 7045, в зависимости от теста.
3. Сохранить baseline до теста и проверить, что события действительно доходят до отдельного индекса лаборатории.
4. Выполнить согласованный тест в изолированной VM и сохранить журнал инструмента, время, статус, stdout/stderr и использованные параметры.
5. Экспортировать сырые события с провайдером, каналом, временем, хостом и идентификаторами. Проверить связь с конкретным запуском, а не только сходство строки.
6. Выполнить детектор на этих свежих данных. Сохранить версию запроса, результат, идентификаторы событий и объяснение соответствия.
7. Проверить cleanup и восстановление snapshot. Зафиксировать остаточные изменения и ограничения.

Даже успешный exit code инструмента не заменяет подтверждение телеметрией. И наоборот, отсутствие совпадения может означать пропущенный сбор логов, неверные поля или непокрытый вариант поведения, а не отсутствие действия.

Источники и версии

Исходное задание Week 9

https://github.com/UnKekGuy/threat-hunting-project/tree/0260464cd692874ce7772a7ffd50a58849448e85/week9

Официальный Atomic Red Team

https://github.com/redcanaryco/atomic-red-team/tree/a0e3f9bc69fed2fd711bd1f1aa87a40c33482fe6

Тесты находятся в atomics/T1053.005/T1053.005.yaml и atomics/T1569.002/T1569.002.yaml этой версии. Используйте GUID из раздела 1, а не порядковый номер, который может измениться.

OTRF Security Datasets

https://github.com/OTRF/Security-Datasets/tree/d9d40ef123d2c87d5d3df28c96bcab4f0faccc87

Конкретные файлы, URL, контрольные суммы и число событий перечислены в output/data-manifest.json. Происхождение файлов задания перечислено отдельно в output/source-manifest.json.

Последняя проверка перед выступлением

- Я могу объяснить каждое условие трёх запросов.
- Я различаю время исходного события и время запуска проверки.
- Я не называю две строки process-запроса двумя процессами.
- Я называю журнал System для 7045 и не приравниваю установку к выполнению.
- Я показываю pinned GUID и не выдаю OTRF за свежие Atomic-события.
- Я называю ограничения проверки на фоновых наборах.
- Я могу открыть сохранённые результаты, если свежая демонстрация недоступна.